MEDRECORDS

Consent & Identity Model

Technical design for the highest-risk component of the platform

1. Why This Document Exists

The original MedRecords concept describes consent and identity in a single paragraph each. Both deserve significantly more thought because they are the design choices most likely to determine whether MedRecords succeeds, fails, or causes harm.

- Identity determines who can claim a record. Get it wrong and either people cannot access their own records, or worse, the wrong person can.
- Consent determines who can read and write to a record. Get it wrong and either clinicians cannot do their job, or patient privacy is breached.
- Both interact: a strong consent model is useless if the identity it binds to is weak; strong identity is useless if consent is fuzzy.

This document specifies both for v1 and lays out the open questions that need product and legal sign-off before build.

2. Identity Model

2.1 Design Goals

- Globally unique within Nigeria. No two MedRecords accounts represent the same human.
- Verifiable. Identity is established once with strong evidence; subsequent authentication is cheaper.
- Resilient to NIMC outages and gaps in NIN coverage.
- Usable for patients across the device spectrum, from iPhones to USSD-only feature phones.
- Transparent to the patient. They can see how they are identified and to whom.

2.2 NIN as the Anchor

Every fully-verified MedRecords account is bound to a National Identification Number. NIN is the only nationwide identifier with the scale, government backing, and biometric verification needed.

What NIN gives us:

- National uniqueness (one human, one NIN)
- Government-backed identity assurance, including biometrics held by NIMC
- An MSISDN (registered phone number) associated with the NIN in most cases, useful for OTP
- A photograph held by NIMC, usable for liveness/match checks during onboarding
- Interoperability paths with other government systems (e.g., NHIA enrolment uses NIN)

What NIN does not give us:

- Coverage of every Nigerian. Approximately 50% of the population is registered as of writing; coverage is highest in urban centers and lowest in rural north.
- Reliable real-time API access. NIMC's verification endpoints have historically been intermittent and rate-limited.
- Photographic match for all individuals — enrolment quality varies and older entries may lack high-quality photos.
- Identity recovery for users who lose access to their registered phone. Handling this is a manual support path.

2.3 Verification Flow

A new patient onboards through the following sequence:

- 1. Patient enters NIN and their phone number in the app.
- 2. Server calls NIMC verification API: confirms NIN exists and matches the provided demographic details.
- 3. Server triggers OTP to the phone number on file with NIMC (not the user-entered number — to prevent SIM-swap takeover).
- 4. Patient enters OTP. If the phone number on file is no longer in use, patient enters a manual recovery flow (see §2.6).
- 5. App captures a selfie. We perform a liveness check and match against the NIMC photo where available. If photo match fails or is unavailable, the account is flagged for manual review.
- 6. Patient sets a 6-digit PIN and (on supported devices) enables biometric login.
- 7. Account is created with status "Verified" or "Pending Review" depending on the photo match result.

2.4 Account States

State	Description
Provisional	Created without NIN verification. Limited features (no exports, no full record visibility to providers). Must convert within 6 months or freeze.
Pending Review	NIN matched but photo match inconclusive. Read-only access. Compliance team reviews within 48 hours.
Verified	Full feature access. Standard state.
Frozen	Account locked for compliance reasons. Data preserved. Read-only access via support.
Deceased	Frozen with deceased flag. Designated executor access via probate documentation.

2.5 Authentication After Onboarding

- Patient app: biometric (FaceID/fingerprint) primary; PIN fallback; OTP for sensitive operations (consent grants to new providers, exports, account changes).
- Provider workstation: username + password + mandatory MFA (TOTP or hardware key). Session timeout of 30 minutes idle, hard 12 hours absolute.
- API integration: OAuth 2.0 client credentials for institutional callers; rate-limited per client; signed audit trail of every call.
- USSD: PIN + phone number; PIN is shorter (4-digit) but combined with SIM possession and rate-limited attempts.

2.6 Identity Edge Cases

Children Under 16

Minors do not own MedRecords accounts. They exist as dependents linked to one or more verified guardian accounts. Each guardian must be at least 18, verified, and able to demonstrate guardianship (uploaded birth

certificate referencing the guardian, court order, or other recognized document; for v1 reviewed manually). At age 16, the dependent record is converted to a provisional account in the child's name and the child is invited to complete verification. Guardian access continues with the new account-holder's consent until age 18.

Dependent Adults

Adults who cannot manage their own record (advanced dementia, severe disability) can be represented by a designated guardian, requiring a court order or recognized medical certification of incapacity. Manual review for v1.

Patients Without NIN

A Provisional Account can be created without NIN. The account holds records but cannot be merged across providers (because we cannot guarantee uniqueness) and cannot export. After 6 months the account is frozen but data is preserved. Once the patient obtains a NIN, they complete verification and we attempt to match and merge any provisional records belonging to them.

Foreigners and Visitors

Foreigners present in Nigeria for healthcare can register a Foreign-Resident Account using a passport. The account is bound to the passport number and country of issue. Records authored under this account are flagged as non-NIN and cannot be merged with a NIN-anchored account later without manual review.

Identity Recovery

A patient who loses their device must re-verify identity. Options: (a) re-trigger NIMC verification with biometric photo match; (b) in-person verification at a partner pharmacy or clinic; (c) compliance team review with supporting documentation. We never recover access purely via knowledge-based questions, which are too easily compromised.

Deceased Patients

Records of deceased patients are preserved indefinitely but frozen. The estate executor may obtain access by presenting a court-issued probate document. Process is manual for v1; we expect this to be a small enough volume that a service desk procedure is sufficient.

2.7 Provider Identity

Providers are verified differently from patients because they have professional licensure that can be authoritatively checked.

- Doctors: verified against MDCN folio number; status (full registration vs provisional) recorded.
- Pharmacists: verified against PCN registration number; renewable license expiry tracked.
- Dentists: MDCN dental wing; same model as doctors.
- Optometrists: ODORBN registration.
- Nurses (later): NMCN; not in v1 scope unless requested by a hospital pilot.
- Facility identity: providers operate at one or more registered facilities. Facility registration with MedRecords requires CAC documents, licence to operate (where applicable), and physical address verification.

A provider whose licence lapses loses write access until renewed. Past records they authored remain attributed to them with the license status at the time of authoring.

3. Consent Model

3.1 Design Goals

- Granular. Patients should be able to share dental records without sharing mental-health history.
- Temporal. Most consent should expire; permanent consent is the exception, not the rule.
- Auditable. Every consent grant, access event, and revocation is logged and visible to the patient.
- Workflow-realistic. A consent flow that takes more than 30 seconds at the clinic reception will not be used.
- Emergency-aware. There must be a path for unconscious-patient care.

3.2 Consent Types

Type	Scope	Duration	Typical Use
Full	All categories	Indefinite or up to 365 days (default 365)	Primary care relationship with a long-standing GP.
Category-limited	Specific categories only	Same as Full or shorter	Specialty relationships — e.g., a dentist gets dental + allergies + active meds.
Time-limited	Any scope above, but with a hard expiry	Hours to weeks	Episode-of-care visits; specialist consultations.
Single-encounter	Encounter-scoped read; auto-expires when encounter closes	Hours, with hard cap	Walk-in visits where the patient does not expect to return.
Dispense-only	Active prescriptions + allergies only	Single use, expires on dispense or 7 days	Pharmacy verifying a prescription.
Break-glass	Read of full record, with provider-supplied justification	24 hours, non-renewable without standard consent	Emergency — patient unconscious or incapable of granting consent.

3.3 Consent Grant Mechanics

Consent grants are issued by the patient. There are three grant channels:

Channel A: Patient-Initiated In-App

Patient opens app, navigates to consent, selects provider (by search or QR scan of provider badge), selects scope and duration, confirms with biometric. Provider receives consent token instantly.

Channel B: Provider-Initiated (Most Common at the Point of Care)

Provider initiates a consent request from their workstation. The system sends a push to the patient app and an SMS fallback. Patient sees the request — provider name, facility, scope, duration — and approves or declines. If the patient does not have the app, they receive an SMS with a one-time code link that opens a lightweight browser flow.

Channel C: Offline / In-Person Code

Patient opens app, generates a one-time access code (QR + 6-digit number, valid for 10 minutes). Provider scans/enters the code, then confirms scope and duration; patient confirms on device. Useful when network conditions are poor or the patient is more comfortable with face-to-face confirmation.

Channel D: USSD

Patient dials a shortcode, enters provider code displayed by the provider, selects scope (limited menu — full/dental/pharmacy/lab), confirms with PIN. Returns a 6-digit code the provider enters. Lower granularity than app channels by design — feature-phone screens cannot support fine-grained selection.

3.4 Consent Token Mechanics

Each granted consent is represented as a cryptographically signed token containing:

```
{ patient_id, provider_id, facility_id, scope[], granted_at, expires_at, jti }
```

Tokens are short-lived (max 24 hours TTL for the access token; refresh handled server-side based on the consent record). Tokens can be revoked server-side at any time; provider clients check token validity on each access. Offline operation uses the locally cached consent record with a 24-hour validity window.

3.5 Break-Glass Protocol

Break-glass is the highest-risk component of the consent model — it is, by definition, access without contemporaneous patient consent. The protocol below treats break-glass as a serious event, not a routine override.

Eligibility:

- Only providers at registered facilities with an Emergency Care designation can invoke break-glass. We will not extend this to general outpatient clinics.
- Only providers with full (not provisional) MDCN/PCN registration.
- Provider's facility must be in good standing (no recent compliance actions).

Invocation:

- Provider opens the patient record (located by NIN, name + DOB, or biometric scan).
- System shows: "Patient consent not on file. Invoking break-glass requires a justification and will be reviewed by compliance."
- Provider selects reason code (Unconscious, Life-threatening emergency, Critical decision required, Other) and types free-text justification (minimum 20 characters).
- Provider re-enters MFA.
- Access is granted for 24 hours, full record, read + write.
- System immediately sends SMS and push notification to the patient (or guardian for minors) with provider name, facility, timestamp, and a link to view the access log.

Post-event review:

- All break-glass events are queued for compliance review within 7 days.
- Sampling: 100% of break-glass events for v1; transitions to risk-based sampling once we have baseline rates.
- Reviewers may request additional context from the provider; unjustified break-glass triggers a facility audit.
- Patients can dispute the access through the app; disputes are investigated within 14 days.

- Repeated break-glass by the same provider without subsequent standard consent (more than three in 90 days) automatically triggers a facility audit.

Why we built it this way:

Emergency care must be possible — refusing break-glass entirely would create patient harm. But the design must make abuse expensive and visible. Mandatory justification, immediate patient notification, and post-event review combine to make break-glass usable in genuine emergencies and unattractive for routine consent bypass.

3.6 Consent Revocation

- Patients can revoke any consent at any time, immediately effective at the server. Provider tokens are invalidated on next call.
- Revocation does not erase records the provider has already authored — those remain in the patient's record, authored by that provider. Authorship is historical fact and cannot be revoked.
- After revocation, the provider can no longer read the patient's records (including the ones they authored), unless and until a new consent is granted.
- Revocation events are visible to the provider as a notification, so they understand the relationship has been ended.

3.7 Special-Category Data

Certain categories of data carry additional sensitivity and require an extra layer of consent beyond standard scope grants:

- HIV status and related test results
- Mental health diagnoses and treatment notes
- Reproductive health, including pregnancy termination history
- Genetic test results
- Substance use disorder records

These categories are stored with field-level encryption keyed separately from the rest of the record. Access requires the standard consent plus an explicit special-category consent that the patient must affirm in a separate UI step. "Full" consent does not implicitly include special-category data; it must be granted explicitly. Break-glass does include access to special-category data because clinical emergencies may require it — but break-glass events involving special-category data are flagged in the audit log with higher review priority.

3.8 Audit Log

- Every read of a record is logged: who, what (which resources), when, under what consent, from what IP/device.
- Every write is logged with the same metadata plus the changed content.
- Logs are append-only and signed; tampering would be detectable.
- Patient can view a chronological feed in the app. Filters: provider, date range, type of access.
- Logs are retained for 7 years per NHA record retention norms; access patterns for population health are retained longer but de-identified.
- Compliance team has read-only access to logs for break-glass review and security investigations; their access is itself logged.

4. NDPA Alignment

The Nigeria Data Protection Act 2023 (NDPA) frames the consent model. Key obligations and how MedRecords meets them:

NDPA principle / obligation	Implementation
Lawful basis	Patient consent for processing; vital interests basis for break-glass; legal obligation for some retention.
Consent must be specific, informed, freely given, unambiguous	Granular scope selection; plain-language descriptions of what each scope means; no bundled consent; revocable any time.
Right of access	Patient app provides full record visibility and audit log access.
Right to data portability	Signed PDF export and FHIR JSON export.
Right to rectification	Patient may request corrections; the provider who authored a record may amend it; amendments are tracked with audit trail.
Right to erasure	Subject to medical record retention obligations under the National Health Act. We do not delete records but we can restrict processing on request.
Data breach notification	Documented incident response with 72-hour NDPC notification commitment.
DPO requirement	Designated DPO from incorporation; contact details visible in app and on website.
Data controller registration	Registered with NDPC before public launch.
Cross-border transfer	All personal data in-country. Limited cross-border for international support if any, behind explicit patient consent.

5. Open Questions

- Should we require a second factor for revocation as well as for grant? (Currently no — revocation is one-tap. Argument for: prevents accidental revocation. Argument against: friction discourages a legitimate exit.)
- Should special-category consent be opt-in (default off) or opt-out (default on with full consent)? Current proposal is opt-in; legal review needed.
- What is the patient app behavior if the patient is unconscious and a family member tries to grant consent? Currently no path; family is encouraged to provide the patient's NIN to the clinician for break-glass.
- How do we handle scenarios where the patient has the app but does not have signal at the moment of care? Channel C (offline code) covers this only if the patient generated the code before signal loss.
- What is the dispute resolution process if a patient claims a break-glass invocation was unjustified? First-line: MedRecords compliance review. Second-line: provider's facility. Third-line: MDCN/PCN regulatory referral. To be formalized with legal counsel.

- Do we ever allow research access without per-patient consent? Current answer: only de-identified, aggregate data, with ethics committee approval, and an opt-out path for patients who do not want their de-identified data used.